transport_security

Transport Security (1.0.0-MVP)

Field	Value
Revision	1
Created	2026-06-07
Last modified	2026-06-07
Status	active
Status summary	Normative MVP specification for transport-layer security of the Helix OTA control plane and Android client: TLS 1.3 throughout, over the LOCKED HTTP/3 (QUIC) primary + HTTP/2 fallback transport with Brotli (→gzip) content compression on control-plane traffic only, served via the `vasic-digital/http3` submodule; certificate management; and an explicit mTLS / certificate-pinning evaluation (recorded as evaluated for MVP, gated to 1.0.1+).
Issues	HelixConstitution clause numbers are UNVERIFIED against the authoritative text. QUIC/UDP-443 reachability across the target fleet, Range-request semantics over HTTP/3 via the `http3` submodule, and Brotli tuning are UNVERIFIED and routed to ADR-0004 §6 spikes. mTLS and certificate pinning are recorded only as “evaluated” in the MVP (master §6; threat_model §4.6/§4.7) — neither is committed for 1.0.0. The TLS-1.3 cipher suites / curve set actually offered by the `http3` and `middleware` catalogue submodules have not been inspected and are UNVERIFIED.
Fixed	N/A (initial revision).
Continuation	Close the ADR-0004 §6 transport spikes (QUIC reachability, Range-over-HTTP/3, Brotli tuning) before the

Field	Value
	dependent code paths are marked stable; inspect `http3` / `middleware` to confirm the TLS-1.3 suite set and Brotli-negotiation surface and remove UNVERIFIED tags; produce a decision record on mTLS + certificate pinning for 1.0.1+ alongside the TUF signed-metadata work (closes the "fake availability" residual).

Table of contents

> The table-of-contents requirement is mandated by HelixConstitution §11.4.61 (UNVERIFIED clause number). This document carries its ToC immediately after the metadata table.

---

1. Purpose and scope

This document specifies transport-layer security for the Helix OTA MVP: how the control plane and Android client are protected **in transit** (TLS 1.3), how that composes with the LOCKED transport stack (HTTP/3 (QUIC) primary, HTTP/2 fallback, Brotli→gzip content compression, REST `/api/v1` primary; gRPC optional/internal only), how certificates are managed, and the explicit decision on mTLS and certificate pinning for the MVP.

It honors, and does **not** re-decide, the LOCKED transport stack from ADR-0004: the protocol, fallback order, compression, and the `vasic-digital/http3` submodule are mandated. Artifact **authenticity/integrity** (signing, hashing, device re-verify) is specified in signing_verification.md; transport security here is the *confidentiality* + *endpoint-authentication* + *tamper-in-transit* layer that sits underneath it. The two are complementary: even if transport were broken, the artifact is re-verified on-device before apply (threat_model §4.6).

2. Threat context for transport

From the threat model (§4.6 MITM on poll/download; §4.7 device impersonation):

- **Artifact integrity is transport-independent.** A MITM cannot forge a valid artifact because the device re-verifies hash + signature + AVB + A/B payload check before apply (threat_model §4.6; signing_verification.md §6–§7). Residual artifact-integrity risk is **low**.
- **Confidentiality + "fake availability" denial are the real transport risks.** The MVP commits to TLS 1.3 but does **not** mandate certificate pinning or mTLS, so a device trusting a rogue CA could be fed forged availability/metadata responses (a denial-of-update vector) even though it cannot forge the artifact itself (threat_model §4.6). The MVP also has no signed, freshness-checked metadata to authenticate the *availability* response — a TUF property deferred to 1.0.1+ (ADR-0002 §3.2 malicious-mirror denial). Residual: **moderate** for confidentiality and fake-availability.
- **Device impersonation** is mitigated in the MVP by a **hardware-id-bound token (Android KeyStore)**, with mTLS recorded only as evaluated (threat_model §4.7); the strength of KeyStore binding on the specific RK3588 / Orange Pi 5 Max board is **UNVERIFIED**.

3. TLS 1.3 baseline

- **TLS 1.3 is mandated throughout** — both on the HTTP/3 (QUIC) path (QUIC carries TLS 1.3 by design) and on the HTTP/2 fallback path (ADR-0004 §4; master §6). Earlier TLS versions are not offered.
- **Applies to every transport class:** control-plane REST `/api/v1` (poll/check-in, rollout assignment, telemetry ingest, dashboard) and the artifact download path are both TLS-1.3 only.
- **Cipher suites / key-exchange:** the concrete TLS-1.3 cipher suite list and key-exchange groups are those exposed by the `http3` / `middleware` catalogue submodules; the exact set has not been inspected and is **UNVERIFIED** (Continuation). TLS 1.3's mandatory AEAD ciphers and forward-secret key exchange are the baseline expectation; no specific suite is asserted here beyond that.
- **Server authentication** in the MVP relies on standard TLS server-certificate validation against the device/client trust roots (§5); endpoint mutual authentication (mTLS) is evaluated, not committed (§6).

4. Transport composition: HTTP/3 (QUIC) → HTTP/2, Brotli two-class rule

This section restates the LOCKED composition from ADR-0004 as it bears on security; it is not re-decided here.

- **Protocol negotiation:** HTTP/3 (QUIC/UDP-443) primary → automatic fallback to HTTP/2 (TCP/TLS 1.3) when QUIC/UDP-443 is unreachable (corporate/middlebox networks frequently block UDP). Served via the `vasic-digital/http3` submodule as a drop-in `net/http.Handler` (ADR-0004 §4; master §3).

REST `/api/v1` is the primary surface; gRPC is optional/internal only (ADR-0004 §3.1; C4).

- **Two-class content compression (security-relevant):**
  - **Control-plane REST/JSON** uses **Brotli**, negotiating to **gzip** for older clients via `Accept-Encoding` (ADR-0004 §3.2).
  - **OTA artifacts are served with NO content compression** (content-encoding `identity`), **byte-identical** and `ZIP_STORED`, with HTTP Range enabled (ADR-0004 §3.2, §4). This is the load-bearing rule: re-compressing the artifact would break both the `update_engine` hash check and the on-device signature re-verify (signing_verification.md §3, §7). A **CI/serving guard** MUST ensure the artifact path is never accidentally Brotli/gzip-compressed (ADR-0004 §5.2).
- **Compression-side-channel note (UNVERIFIED, new):** compression oracle attacks (CRIME/BREACH-class) apply only to TLS-protected *compressed* responses that mix secrets with attacker-controlled input. The control-plane REST/JSON responses are Brotli-compressed under TLS 1.3; whether any endpoint reflects attacker-controlled input alongside a secret (e.g. a token) in a single compressed response must be reviewed. No such endpoint is asserted to exist; this is recorded as a review item (Continuation), not a confirmed finding. The artifact path is uncompressed and not exposed.
- **Negotiation order at the edge:** HTTP/3 → HTTP/2 → content-encoding `br` → `gzip` → `identity`; the artifact path is pinned to `identity` + Range regardless of control-plane negotiation (ADR-0004 §4).

5. Certificate management

The MVP server-certificate posture (no certificate clause is re-decided from ADR-0004; this is the operational specification):

- **Server certificates** terminate TLS 1.3 on the control plane edge. Issuance, renewal, and rotation are an **operational process** (e.g. an ACME-style automated issuer or an organization-internal CA); the specific issuer is a deployment choice and is **not pinned here** (recorded as a deployment decision, not asserted).
- **Trust roots on the device:** the Android client validates the server certificate chain against its configured trust roots. In the MVP this is **standard chain validation** (no pinning; §6). The set of trusted roots is a build/config input via `Config-KMP` (master §6 device config).
- **Separation from the signing trust store.** The TLS **certificate** trust (who the server *is*) is distinct from the **artifact-signing** trust store (which build-pipeline public key signs releases; key_management.md). Compromise of a TLS certificate does **not** let an attacker forge an artifact, because the artifact signature is verified against the *signing* trust store on-device (signing_verification.md §6; threat_model §4.6). These two trust anchors are managed and rotated independently.
- **QUIC certificate use:** QUIC uses the same X.509 server certificate / TLS-1.3 handshake; no separate QUIC-specific certificate scheme is introduced.
- **Renewal/rotation cadence and revocation handling** (OCSP/CRL behavior on-device) are deployment parameters; the device must fail safe (abort the update attempt, retry on next poll) on a failed TLS handshake rather than downgrade. The exact revocation-checking behavior on the RK3588 / Orange Pi 5 Max Android build is **UNVERIFIED**.

6. mTLS and certificate-pinning evaluation

The MVP **records mTLS and certificate pinning as evaluated, and commits to neither** (master §6; threat_model §4.6, §4.7). This section is that evaluation.

Option	What it adds	MVP decision	Rationale
TLS 1.3, standard chain validation (CHOSEN, MVP)	Confidentiality + tamper-in-transit + server authentication against trust roots	**Adopt**	Mandated baseline (master §6; ADR-0004 §4). Sufficient because artifact authenticity is enforced independently on-device (threat_model §4.6).
Certificate pinning (device pins server cert/ SPKI)	Closes the rogue-CA “fake availability” / forged-metadata vector (threat_model §4.6)	**Evaluated; deferred to 1.0.1+**	Raises operational risk (a mis-rotated pin bricks fleet connectivity); the residual it closes is a *denial/ confidentiality* vector, not an artifact-forgery vector, which is already covered. Best paired with the TUF signed-metadata work (ADR-0002 §3.2) that authenticates the availability response itself.
mTLS (device presents a client certificate)	Strong device authentication at the transport layer; complements the KeyStore-bound token (threat_model §4.7)	**Evaluated; deferred to 1.0.1+**	The MVP already binds device identity to hardware via an Android-KeyStore token (master §6; threat_model §4.7); mTLS adds per-device certificate provisioning/ rotation overhead at fleet scale. Best landed with the per-device Director-style targeting reserved

Option	What it adds	MVP decision	Rationale
			in ADR-0002 §4.2.

MVP residual accepted: without pinning or mTLS, a device trusting a rogue CA can be fed forged availability/metadata responses (denial-of-update), and device authentication rests on the KeyStore-bound token whose binding strength on RK3588 is **UNVERIFIED** (threat_model §4.6, §4.7). These are tracked, not fixed, in the MVP; the forward path is pinning + mTLS + TUF signed metadata in 1.0.1+ (threat_model §4.6 “1.0.1+”; ADR-0002).

7. Catalogue reuse and module boundaries

Per catalogue-first reuse (§11.4.74, UNVERIFIED clause); transport is composed, not hand-rolled (ADR-0004 §4 item 6):

Concern	Submodule(s)	Class	Boundary
HTTP/3 (QUIC) handler + HTTP/2 fallback + TLS 1.3	`http3` (`vasic-digital/http3`)	reuse	Drop-in `net/http.Handler`; carries no business logic. UNVERIFIED: exact TLS-1.3 suite set offered.
Brotli⍰gzip content negotiation (control-plane only)	`middleware`	reuse / extend	Content-negotiation in `middleware`; artifact path forced to `identity`. UNVERIFIED that Brotli negotiation is already present (reuse map §5 — possible upstream `extend`).
Request throttling (anti-DoS at the edge)	`ratelimiter`	reuse	Throttles control-plane endpoints; no transport logic.
Panic recovery on the request path	`recovery`	reuse	Edge resilience; no business logic.
Byte-identical, Range-enabled artifact serve	`Storage`	reuse	Serves OTA blobs over HTTPS with Range; never compresses the artifact.
Device-side trust roots / TLS config	`Config-KMP`	reuse	Carries device trust-root + transport config.

Concern	Submodule(s)	Class	Boundary
Server request-auth / device-token validation	`auth`, `middleware`; device: `Auth-KMP`, `Security-KMP`	reuse	Token (KeyStore-bound) validation; mTLS would extend here in 1.0.1+.

REST/wire contracts come from `ota-protocol` (NEW); transport carries no business logic (reuse map §3 Transport).

8. Testing (four-layer)

Per HelixConstitution §1 (UNVERIFIED clause), with no-bluff positive evidence (§7.1). Transport correctness (TLS 1.3 enforced, fallback works, artifact path uncompressed) is treated as a safety-relevant serving path:

- **Layer 1 — Source-presence gate.** Static check that the source: configures TLS 1.3 as the minimum (no downgrade to TLS ≤1.2); wires the `http3` handler with HTTP/2 fallback; applies Brotli negotiation to control-plane routes only; pins the artifact route to `identity` content-encoding + Range; and does not send `DISABLE_DOWNLOAD_RESUME` (ADR-0004 §4). Absence is a build-time failure.
- **Layer 2 — Artifact gate (bytes shipped).** Confirm the served OTA artifact is **byte-identical** (no Brotli/gzip transfer-encoding on the artifact response) and `ZIP_STORED`; confirm the device build embeds the configured TLS trust roots; confirm no TLS ≤1.2 cipher config is shipped.
- **Layer 3 — Runtime / integration.** End-to-end: (a) a TLS-1.3 HTTP/3 handshake succeeds and a poll/assignment round-trips; (b) with UDP/443 blocked, the client **falls back to HTTP/2** and the same round-trip succeeds (ADR-0004 §6 reachability spike); (c) a control-plane response is Brotli- then gzip-negotiated; (d) the **artifact download is uncompressed and Range-correct** (stream a real `ZIP_STORED` `payload.bin`, confirm byte-range + resume; ADR-0004 §6 spike). **Negative cases:** a TLS ≤1.2 client is refused; a Brotli/gzip-compressed artifact response is rejected by the CI/serving guard; a tampered-in-transit artifact is caught by the device re-verify gate (signing_verification.md §6).
- **Layer 4 — Mutation meta-test (PASS→FAIL on negation).** Mutate transport config/guards and require PASS→FAIL: lower the TLS minimum to 1.2, enable Brotli on the artifact route, or disable Range — each MUST be caught by Layer 1/2/3. A surviving mutant is a defect.

The QUIC reachability, Range-over-HTTP/3, and Brotli-tuning spikes (ADR-0004 §6) are the rock-solid- proof closures for the carried UNVERIFIED transport items and gate marking the corresponding paths stable.

9. Open / UNVERIFIED items

1. **QUIC/UDP-443 reachability** across the target fleet and the HTTP/2 fallback trigger — **UNVERIFIED (needs spike)** (ADR-0004 §6 item 3).
2. **Range-request semantics over HTTP/3 via the `http3` submodule + MinIO/S3 — UNVERIFIED** (ADR-0004 §6 item 1).

3. **Brotli quality/parameter tuning** for control-plane JSON at fleet scale — **UNVERIFIED** (ADR-0004 §6 item 4).
4. **`http3` / `middleware` TLS-1.3 cipher-suite set and Brotli-negotiation surface** — not inspected, **UNVERIFIED** (reuse map §5).
5. **mTLS / certificate pinning** are **evaluated, not committed** in the MVP; the rogue-CA fake- availability residual and KeyStore-binding strength on RK3588 are accepted MVP residuals (threat_model §4.6, §4.7).
6. **On-device revocation-checking behavior** (OCSP/CRL) on the RK3588 / Orange Pi 5 Max Android build — **UNVERIFIED**.
7. **HelixConstitution clause numbers** — **UNVERIFIED** (corpus convention).

10. Compliance notes (HelixConstitution)

Clause (UNVERIFIED numbers)	How this spec complies
§11.4.61 (ToC)	ToC present immediately after the metadata table.
§7.1 / §11.4.6 (no-bluff / no-guessing)	Every claim cites ADR-0004, master §6, or the threat model; reachability, Range-over-HTTP/3, Brotli tuning, suite sets, and mTLS/pinning status are carried as **UNVERIFIED** or “evaluated”, not asserted.
§11.4.74 (catalogue-first reuse)	Transport composed from `http3`, `middleware`, `ratelimiter`, `recovery`, `Storage`, `Config-KMP`, `auth`; no hand-rolled QUIC/Brotli/TLS stack (§7).
§11.4.28 (decoupling)	Transport carries no business logic; contracts in `ota-protocol`; artifact-serve path isolated from control-plane compression (§4, §7).
§1 / §1.1 (four-layer + mutation)	§8 specifies all four layers, including TLS-downgrade and artifact-compression mutations.
§11.4.123 (rock-solid proof)	The ADR-0004 §6 spikes + Layer-3 runtime evidence close each UNVERIFIED transport claim before the path is marked stable (§8).
§11.4.125 (code-review gate)	Subject to the mandatory adversarial code-review subagent before acceptance (master §14).

11. Sources

All paths relative to `docs/research/main_specs/`:

- `research/adr/adr-0004-transport.md` — §3.1–§3.2, §4, §5, §6 (TLS 1.3, HTTP/3→HTTP/2, two-class compression, Range, spikes).

- `research/adr/adr-0002-supply-chain-trust.md` — §3.2 (malicious-mirror denial), §4.2 (per-device Director reservation).
- `00-master/2026-06-07-helix-ota-design.md` — §3 (mandated stack), §6 (security & trust model: TLS 1.3, device identity, mTLS evaluated), §13 (four-layer testing).
- `00-master/threat_model.md` — §4.6 (MITM on poll/download), §4.7 (device impersonation).
- `00-master/submodule_reuse_map.md` — §3 (Transport), §5 (upstream additions: Brotli negotiation in `middleware`).
- `00-master/documentation_standards.md` — §2 (metadata), §8 (anti-bluff), §9 (canonical submodules).
- signing_verification.md, key_management.md — companion MVP security specs.